

Seminário de Infraestrutura e Segurança

Cofres de Senhas

Secrets Management: Conteúdo Teórico

Eduardo, Talles e Kaléu

IFSC - Análise e Desenvolvimento de Sistemas

2026

Sumário

- 1 Introdução
- 2 Cofre X Gerenciador
- 3 O Problema
- 4 Casos de Uso
- 5 Soluções no Mercado
- 6 HashiCorp Vault

Introdução

O Que É um Cofre de Senhas?



Solução centralizada e especializada para armazenar, gerenciar, distribuir e auditar o acesso a informações altamente sensíveis denominadas **segredos** (secrets).

Tipos de segredos gerenciados:

- **Chaves de API:** Acesso a serviços externos (pagamentos, e-mail).
- **Credenciais de Banco de Dados:** PostgreSQL, MySQL, MongoDB, etc.
- **Tokens de Acesso:** OAuth, JWT, GitHub, GitLab.
- **Certificados e Criptografia:** Certificados TLS/SSL e chaves privadas.
- **Cloud & Infraestrutura:** AWS IAM, Azure AD, variáveis sensíveis.

Evolução e Escala

Single Source of Truth

Substitui arquivos dispersos e variáveis não gerenciadas por um repositório único, protegido por múltiplas camadas de controle.

! Importante

A Nova Realidade

Com a nuvem e os microserviços, o número de identidades não-humanas (NHIs) cresceu exponencialmente. O mercado de *Secrets Management* projeta movimentar USD 8,05 bilhões até 2030.

Cofre X Gerenciador

Gerenciador vs. Cofre de Senhas

Dimensão	Gerenciador (Password Manager)	Cofre (Secrets Management)
Usuário Primário	Ser humano	Aplicação / Máquina / Pipeline
Interação	Manual, via interface gráfica	Programática, via API/SDK/CLI
Credenciais	Contas pessoais e corporativas	API keys, DB credentials, Tokens
Escala	Dezenas a centenas de senhas	Milhões de requisições por dia
Rotação	Manual ou assistida	Automática (TTL configurável)
Foco	Produtividade e Privacidade	Compliance (SOC 2, PCI-DSS)

O Problema

Por que precisamos de Cofres?



Secret Spreading (Espalhamento de Segredos)

A proliferação descontrolada de segredos por lugares inseguros. Apenas em 2024, **23,77 milhões** de novos segredos foram expostos no GitHub (GitGuardian, 2025).

Como os vazamentos ocorrem:

- **Hardcoding:** Credenciais direto no código-fonte versionado.

Por que precisamos de Cofres?



Secret Spreading (Espalhamento de Segredos)

A proliferação descontrolada de segredos por lugares inseguros. Apenas em 2024, **23,77 milhões** de novos segredos foram expostos no GitHub (GitGuardian, 2025).

Como os vazamentos ocorrem:

- **Hardcoding:** Credenciais direto no código-fonte versionado.
- **Arquivos de Configuração:** `.env` ou `application.properties` commitados acidentalmente.

Por que precisamos de Cofres?



Secret Spreading (Espalhamento de Segredos)

A proliferação descontrolada de segredos por lugares inseguros. Apenas em 2024, **23,77 milhões** de novos segredos foram expostos no GitHub (GitGuardian, 2025).

Como os vazamentos ocorrem:

- **Hardcoding:** Credenciais direto no código-fonte versionado.
- **Arquivos de Configuração:** `.env` ou `application.properties` commitados acidentalmente.
- **CI/CD Inseguro:** Segredos em formato de texto plano nos pipelines.

Por que precisamos de Cofres?



Secret Spreading (Espalhamento de Segredos)

A proliferação descontrolada de segredos por lugares inseguros. Apenas em 2024, **23,77 milhões** de novos segredos foram expostos no GitHub (GitGuardian, 2025).

Como os vazamentos ocorrem:

- **Hardcoding:** Credenciais direto no código-fonte versionado.
- **Arquivos de Configuração:** `.env` ou `application.properties` commitados acidentalmente.
- **CI/CD Inseguro:** Segredos em formato de texto plano nos pipelines.
- **Mídias informais:** Slack, planilhas e wikis corporativas.

Exemplo Prático: Arquivo .env

Configuração enviada acidentalmente para o Git

```
# Credenciais de Banco de Dados de Produção
DB_HOST=prod-database.empresa.com.br
DB_USER=admin_db
DB_PASSWORD=SuperSenhaSecreta123!

# Chaves de Nuvem (AWS)
AWS_ACCESS_KEY_ID=AKIAIOSFODNN7EXAMPLE
AWS_SECRET_ACCESS_KEY=wJalrXUtnFEMI/K7MDENG/bPxRfiCY...
```

Desafios Operacionais

⚠ Atenção

Falta de Auditoria

Quem rotacionou a chave? Quando?
É impossível responder sem centralização, prejudicando a conformidade com a LGPD e normas como SOC 2.

⚠ Atenção

Acesso de Longa Duração

Chaves de API antigas nunca expiram. O cofre introduz *Time-To-Live* (TTL) e rotação contínua para minimizar riscos.

Casos de Uso

Onde e Como é Utilizado

- **Aplicações → Bancos de Dados:** A app consulta o cofre em tempo real em vez de ler strings de conexão fixas.
- **Pipelines CI/CD:** Credenciais temporárias geradas apenas para fazer o *deploy* ou *push* da imagem.
- **Microserviços:** Atua como autoridade central de identidade para a comunicação M2M (Máquina a Máquina).
- **Infraestrutura como Código (IaC):** Integração direta com Terraform/Ansible sem salvar dados no estado local.
- **Kubernetes:** Injeção de segredos direto na memória do Pod, evitando o fraco *Base64* dos Kubernetes Secrets.

Exemplo Prático: Resgatando um Segredo via CLI

Em vez de ler um arquivo `.env`, a aplicação ou desenvolvedor solicita o segredo dinamicamente ao Vault:

Comando no Terminal

```
# Autenticacao no cofre
```

```
$ vault login s.1234567890abcdefToken
```

```
# Requisitando a credencial do banco de dados
```

```
$ vault kv get -field=password secret/producao/db
```

```
SuperSenhaSecreta123!
```

Neste fluxo, o segredo não fica salvo na máquina. Ele fica apenas na memória da aplicação durante a execução.

Soluções no Mercado

Ecosystem de Secrets Management

Agnósticas (Multi-Cloud)

- **HashiCorp Vault:** O padrão de mercado (*gold standard*).
- **CyberArk Conjur:** Foco em governança corporativa.
- **Doppler / Infisical:** Focados na experiência do desenvolvedor (DevX).

Nativas de Nuvem

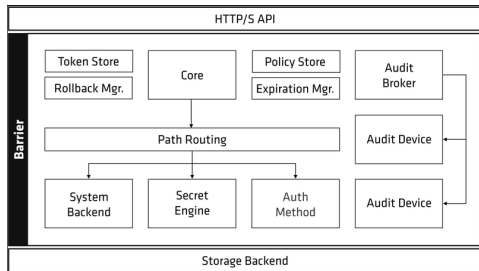
- **AWS Secrets Manager**
- **Azure Key Vault**
- **Google Secret Manager**

HashiCorp Vault

HashiCorp Vault: Arquitetura

Mais que armazenamento passivo, o Vault gera, revoga e rotaciona segredos dinamicamente.

- **Storage Backend:** Delega a persistência (Consul, Raft), gravando cifrado.
- **Barrier:** Camada interna baseada em AES-256-GCM.
- **Seal/Unseal:** Requer fragmentos criptográficos (Shamir's) para liberar.
- **Auth & Policies:** Validação e regras granulares.



Conclusão

- **Necessidade, não luxo:** O uso de cofres é essencial para conformidade (LGPD, SOC 2) e segurança contra vazamentos.
- **Foco em Máquinas:** A automação e as identidades não-humanas exigem credenciais dinâmicas e rotação contínua.
- **Fim do Hardcoding:** É imperativo banir credenciais fixas de códigos-fonte, pipelines e arquivos de configuração.
- **Criptografia como Serviço:** Centralizar a gestão de chaves tira o fardo do desenvolvedor e garante um padrão ouro de segurança.

Dúvidas?

Muito obrigado pela atenção!

Eduardo, Kaléu e Talles

Referências I



AMAZON WEB SERVICES. **AWS Secrets Manager - Documentação Oficial**. 2026. Disponível em: <https://docs.aws.amazon.com/secretsmanager/>.



GITGUARDIAN. **State of Secrets Sprawl 2025**. 2025. Disponível em: <https://www.gitguardian.com/state-of-secrets-sprawl-report-2025>.



GOOGLE CLOUD. **Google Cloud Secret Manager - Documentação Oficial**. 2026. Disponível em: <https://cloud.google.com/secret-manager/docs>.



HASHICORP. **HashiCorp Vault - Documentação Oficial**. 2026. Disponível em: <https://developer.hashicorp.com/vault/docs>.



HASHICORP. **What is Vault?** 2026. Disponível em: <https://developer.hashicorp.com/vault#what-is-vault>.

Referências II



MICROSOFT. **Azure Key Vault - Documentação Oficial**. 2026. Disponível em: <https://learn.microsoft.com/azure/key-vault/>.



PCI SECURITY STANDARDS COUNCIL. **Payment Card Industry Data Security Standard**. 2026. Disponível em: <https://www.pcisecuritystandards.org/>.